BIGCOMMERCE

BigCommerce Infrastructure and Platform Security Guide

For CISOs, CIOs, and CTOs



Table of Contents

- Table of Contents 2
- Introduction 3
- Our Dedicated Security, Privacy & Compliance Teams 3
- Cloud Security 4
  - Backed by the Security of Google Cloud Data
  - Open Software-as-a-Service (SaaS) Methodology
  - Uptime, Traffic Spikes, and Load Balancing
  - High Availability Infrastructure
- Platform Security 6
  - Multi-Factor Authentication
  - Least Privilege Role Management
  - Distributed Denial of Service (DDoS) Attack Protection
  - Cloud Compliance
  - Secure Coding and Business Practices
- Data Security 8
  - Payment Card Industry Data Security Standard (PCI DSS)
  - Encryption by Default, At Rest, and In-Transit
  - Data Backup and Disaster Recovery
- Security Certifications 9
  - PCI AOC
  - ISO/IEC 27001
  - ISO 27701
  - ISO 22301
  - SOC1 Type 2 and SOC2 Type 2
- Summary and Further Resources 11
- About the Author 13

Introduction

Spend less time managing your tech, hunting down vulnerabilities, and putting out fires. We provide a complete ecommerce platform with best-in-class security practices and technologies, so you can worry less and build more.

To meet the demands of your business, you have requirements for availability, scalability, reliability, and performance — but none of those can come at the cost of security and privacy. Choosing the right platform to power your online presence requires careful deliberation and diligence.

At BigCommerce, we know that security is more than just tools. It's about people, processes, and trust. Security is a responsibility we take to heart — and it's instrumental in building the trust we've earned with our partners, customers, and employees. From our company culture to our technology platform, we strive to be transparent and collaborative with our security practices.

Discover how BigCommerce secures its cloud infrastructure, platform, and data.

Our Dedicated Security, Privacy & Compliance Teams

BigCommerce's security engineers are committed to protecting our customers' information. Our product development teams pair with application security engineers to ensure every launch meets security and privacy requirements. Our infrastructure engineering team partners with Infrastructure security engineers to ensure network and infrastructure security requirements are met.

NIST risk-based framework is the foundation of our cybersecurity program. At the BigCommerce global Security Operations Center, protecting data is core to our operations.

Cloud Security

Imagine a world in which your organization is no longer responsible for maintaining and monitoring infrastructure, installing updates, or providing first-line response and detection for minor security events.

BigCommerce is a multi-tenant software-as-a-service (SaaS) ecommerce platform running on industry-leading cloud hosting infrastructure. Reallocate your internal staff to spend more time innovating and improving customer experience — and less time on tactical maintenance.

Backed by the Security of Google Cloud Data

BigCommerce platform is hosted in Google Cloud Data Centers across the United States, Europe, and Australia. We use Google Cloud Platform (GCP) because it is one of the industry's fastest, most flexible, and most secure cloud hosting infrastructures.

Backed by a rigorous system of independent audits that certify the platform's security, privacy, and compliance controls, GCP provides additional protection for BigCommerce merchants via its multi-layered approach to security, global infrastructure, and round-the-clock monitoring. Our merchants are the controllers of their data and, as such, are provided their own database in which to store encrypted customer data. This combined results in extraordinary resilience against DDoS attacks and other malicious behavior.

For production traffic, we utilize three Google Cloud Regions as our primary data storage locations: the U.S. (Central U.S. region), Australia (Southeast region), and Germany (West Europe region). Across these regions, the BigCommerce infrastructure is replicated throughout multiple availability zones. Cardholder Data Environments are logically segmented from non-Cardholder Data Environments. Additionally, some ancillary services not integral to running the BigCommerce platform are hosted on Amazon Web Services.

Through these data centers and our strict adherence to PCI DSS standards, each BigCommerce store is protected by multiple layers of security to prevent unauthorized access. This includes cloud security posture management (CSPM) and integrated global cloud network protection. Our secure-by-design infrastructure includes perimeter and host-based firewalls, file integrity monitoring, (Web Application Firewalls) WAF, intrusion detection, application firewalls, and 24/7 monitoring by our global Cybersecurity Team. Google's health checking and auto-healing are engaged.

You can read more about this in our Platform Trust Center. BigCommerce and Google Cloud independent third-party certifications are also available upon request.

Open Software-as-a-Service (SaaS) Methodology

You want the security, stability, and engineer-tested appeal of an open-source solution — with the management and maintenance of SaaS. BigCommerce provides the best of both worlds with our openSaaS software philosophy.

As an openSaaS platform, BigCommerce can shore up vulnerabilities anytime — pushing new code into production to swiftly resolve potential exploits and/or deliver more value to merchants. Through our robust CI/CD practices, we ensure new features, fixes, and improvements don't disrupt our merchants, despite pushing code to the production environment at least three times a day.

Security is a core feature of the BigCommerce platform. Our core application is written with best-in-class development tools; source code is not only tested by independent security service companies but also by our Global Cybersecurity Application Security engineers and public Bug Bounty program. Dynamic, static, performance and open-source testing is built into our continuous integration pipeline.

Uptime, Traffic Spikes, and Load Balancing

You can't sell if you're offline. Whether it's the malicious traffic of a DDoS attack or the high-volume traffic associated with holiday shopping, BigCommerce has the stability to keep you generating revenue.

To maintain this uptime, the BigCommerce platform undergoes regular load and performance testing. We have an internal framework that tells us how many requests per second our platform can serve with acceptable performance and can scale linearly by adding more application servers. We always carry at least twice our peak load in server capacity, scaling up or down as necessary. And we leverage a CDN for faster delivery and the lowest latency to your customers.

BigCommerce engineers use many internal and external tools and services to monitor our platform. Leveraging internal tools and third-party cloud services, we monitor external performance and availability, trending and alerting, and more specific application-based metrics. We also have an extensive internal log analysis system.

High Availability Infrastructure

BigCommerce operates on a High Availability (HA) durable infrastructure that allows us to provide better uptime, resiliency, and performance for our merchants. This environment offers cost-effective failover protection against hardware and operating system outages, where stores are not assigned to a single server, which eliminates any single points of failure.

The HA environment allows us to increase capacity for all stores just by expanding our infrastructure as needed. Our ecommerce platform is fully virtualized, Infrastructure-as-Code. Due to the nature of our multi-tenant SaaS platform, when our platform scales to handle higher traffic, all stores across the BigCommerce platform benefit.

Platform Security

Security is the utmost concern for any technology leader. As such, every part of the BigCommerce platform is built with security top of mind. All BigCommerce systems are kept on Linux, with no reliance on Windows hosts. Patches are applied weekly to catch even the most current of newly discovered threats.

Highly critical security patches (such as Heartbleed and POODLE) are applied automatically without downtime, freeing up your technology resources. Alerts and logs generated by our security infrastructure are monitored continuously in real-time for security policy violations and intrusion attempts. We perform penetration testing annually and employ several different technologies for guarding against malware, DDoS, and spam.

Multi-Factor Authentication

By default, staff user accounts are protected with email verification on top of username and password. For additional protection, merchants can use two-factor authentication to ensure only legitimate users can log in and manage the store.

Least Privilege Role Management

We build our security philosophy directly into our merchant platform — so operationally, you can enforce least-privilege roles within the platform. Manage your organization's most essential ecommerce data more securely where it lives by ensuring that users and operators of your merchant site never have more access than they should on a granular level.

> **"We appreciate how BigCommerce takes care of all the IT stuff like firewalls and intrusion detection to make sure our site remains up. This was really a big thing for us in terms of switching over to BigCommerce."**
>
> JUSTIN NUTZMAN, ECOMMERCE DIRECTOR, RED APPLE FIREWORKS

Distributed Denial of Service (DDoS) Attack Protection

BigCommerce features built-in DDoS mitigation and defensive capabilities across the entire platform, provided at no extra cost to all BigCommerce customers. Our DDoS technology builds on industry-leading defensive capabilities offered by Google Cloud and Cloudflare, which includes mitigation capabilities designed specifically for the BigCommerce platform. Our infrastructure and cybersecurity teams, on-call 24/7/365, are available for instant additional mitigation.

Cloud Compliance

New regulations in cloud compliance are constantly emerging, such as the increased need to locate where your data physically lives across the globe. BigCommerce undergoes independent verification of our security controls to meet our security objectives and ensure the platform's security for our clients — so you don't have to.

Secure Coding and Business Practices

BigCommerce follows ISO 27001 and PCI DSS 3.2.1 requirements for secure development practices and training for our developers. We follow best practices from NIST, OWASP, and CIS. We have a secure product development framework that includes continuous integration and deployment, integrated static and dynamic code analysis, open-source software composition analysis, and manual penetration testing.

Additionally, all BigCommerce employees undergo Information Security Awareness training during onboarding and again annually. All developers must take a day-long Secure Development Training before being given access to the codebase, and they must retake their training annually, or their access is revoked. Finally, we conduct continuous security scans of our production infrastructure to ensure security patches are current.

> **"BigCommerce makes sure that everything is secure," said Chelsey Eggert, Director of Operations for BB Wheels. "We don't have to worry about our site being hacked or maintaining it. Also, it helps to have BigCommerce on the backend, so we can focus on selling products."**
>
> DEAN GOEBEL, PRESIDENT, BB WHEELS

Data Security

PCI DSS, GDPR, and even CPRA — modern data must be secure and available. At BigCommerce, we meet PCI DSS compliance standards and data encryption best practices, reducing the risk of data falling into the wrong hands.

Payment Card Industry Data Security Standard (PCI DSS)

The main governing framework for security in the payments industry is the Payment Card Industry Data Security Standard (PCI DSS). BigCommerce is certified as a PCI DSS Level 1 Service Provider and a PCI DSS Level 1 Merchant, which ensures protection against credit card data breaches and eliminates the massive cost and hassle of handling compliance yourself. The standard includes requirements for access management, change management, infrastructure security, patching, and incident response. BigCommerce follows extensive security policies and procedures governing PCI Compliance.

Encryption by Default, At Rest, and In-Transit

BigCommerce supports the latest versions of TLS (TLS v1.2 and TLS v1.3) and ensures old and less secure versions of TLS and SSL ciphers with known weaknesses are not supported. All merchants have a shared TLS certificate by default that is used on a .mybigcommerce.com domain.

Once a merchant applies a custom domain name to their store, BigCommerce will automatically provision a free private SSL via Encryption Everywhere. Additionally, merchants can use a third-party TLS certificate or purchase a “True BusinessID w/ EV” certificate for extended verification.

Data Backup and Disaster Recovery

All BigCommerce stores have their data replicated and are active in four data centers for greater redundancy and availability. These data centers are spatially separated to mitigate any potential failure. Production servers are backed up every day to remote backup servers. Remote storage of backups ensures that merchant customer data captured via the backup process will survive a disaster impacting all production data centers and will be available for restoration on alternative infrastructure. Our ISO 22301 certification underscores our commitment to business resilience.

Security Certifications

We are constantly updating our security certifications and procuring new certifications as they become available — to ensure the best security practices even across a constantly shifting landscape. For the most recent or to access documentation related to these certifications, please see our Platform Trust Center.

PCI AOC

The Payment Card Industry Data Security Standard (PCI DSS) is a proprietary information security standard administered by the PCI Security Standards Council, founded by American Express, Discover Financial Services, JCB International, MasterCard Worldwide and Visa Inc.

PCI DSS is a set of network security and business best practices guidelines adopted by the PCI Security Standards Council to establish a "minimum security standard" to protect customers' payment card information. The scope of the PCI DSS includes all systems, networks, and applications that process, store, or transmit cardholder data, and also systems that are used to secure and log access to the systems in scope.

BigCommerce undergoes at least an annual third-party audit to certify our e-commerce platform against the PCI DSS. BigCommerce is a Level 1 Merchant and a Level 1 Service Provider. PCI DSS Level 1 is the highest level of compliance and payment security standards merchants can comply with to securely store, transmit, and process credit card information.

> **"I think the key thing here is that we are able to make those changes fairly easily. Whereas with Magento 2, it was quite a long drawn-out process to make changes, testing, making sure that any updates or security patches would work with the updates that we were making. For me, BigCommerce just works."**
>
> DAVID WINSTANLEY, DIRECTOR, WINSTANLEYS PRAMWORLD

ISO/IEC 27001

BigCommerce is certified as ISO/IEC 27001 compliant, which enables a comprehensive and continually improving model for security management. ISO/IEC 27001 outlines and provides the requirements for an information security management system (ISMS), specifies a set of best practices, and details the security controls that can help manage information risks.

ISO 27701

ISO 27701 is a leading privacy certification based on the recognized international standard for privacy information management systems, which outlines controls and processes for managing data privacy and protecting personally identifiable information.

ISO 27701 certification reflects BigCommerce's commitment to ensuring that the company does not use, disclose, or retain platform personal data except as authorized by our merchants. This standard is the only ISO framework aligned with the General Data Protection Regulation (GDPR) to the extent that the framework includes a mapping to GDPR.

ISO 22301

ISO 22301 is a leading business resilience certification based on the recognized international standard for business continuity management systems, which outlines controls and processes for managing business resilience. Our ISO 22301 certification underscores our commitment to business resilience.

SOC1 Type 2 and SOC2 Type 2

With these reports, BigCommerce merchants — particularly enterprise customers — can feel more confident than ever regarding the controls and processes to protect their data. SOC 1 and SOC 2 certifications improve a merchant's ability to meet SOX requirements, while SOC 2 enables a merchant to meet the third-party risk requirements associated with choosing an ecommerce platform.

> **Magento 2 was very resource intensive for updates and security patches. And, all of our development budget was spent maintaining the site, not actually delivering any new features or helping the business grow."**
>
> DAVID WINSTANLEY, DIRECTOR, WINSTANLEYS PRAMWORLD

Summary and Further Resources

Feel confident with your choice of ecommerce platform. At BigCommerce, we've significantly invested in our platform security and infrastructure — so you can focus more on innovation and less on maintenance.

BigCommerce is a member of the RH-ISAC, a secure place for consumer-facing companies to share cybersecurity information and intelligence to not only protect their own companies but also to strengthen the entire sector. While retail is all about competing on price, product, distribution, etc., we don't compete on the security of our merchants' data or our data.

BigCommerce is committed to earning and maintaining a trusting relationship with our customers through continuous improvements to our security posture and transparency in our processes. Since 2021, we have been awarded a growing list of certifications and reports attesting to the maturity of our security, privacy, and business resilience programs.

Visit the BigCommerce Platform Trust Center for specific information on our compliance certifications and ongoing updates.

> **"With BigCommerce we were able to build a reliable site that gave us more capacity when we needed it and less when we didn't. We're not checking every 15 minutes to see if the website is working. We just have confidence that the site is up, running, it's secure and performing"**
>
> ANDREW HASSARD, OWNER AND MANAGING DIRECTOR, MANGO BIKES

The BigCommerce Cybersecurity team:

- Audits our environment daily by reviewing logs from our Intrusion Detection and File Integrity Monitoring systems
- Conducts secure code review and security testing of code prior to deployment
- Performs Internal/External Penetration Testing regularly
- Hires an external PCI compliance vendor to audit our continuous vulnerability scanning capability
- Hires both internal and external ISO/IEC ISO27001 auditors annually to certify our information security management system.
- Is organized around, and aligned with NIST 800-53, ISO/IEC 27001:2013, and SOC2 Type II controls
- Conducts continuous vulnerability scanning
- Adheres to jurisdictional privacy requirements, such as GDPR, CCPA, and the Australian Privacy Act
- Invests in security by running a vulnerability disclosure program and a BugBounty program that pays security researchers for reporting security issues.
- Automates security updates
- Encrypts sensitive payments data (including PAN, CVV2, and expiration date) in transit and doesn't allow data to come to rest on BigCommerce infrastructure
- Trains employees on best practices to comply with PCI DSS based on the following documentation:
- Secure Coding Practices include testing for OWASP Top 10 security risks.
- BigCommerce's PCI DSS Attestation of Compliance.
- Provides merchants with tools to manage the security and privacy of their stores.
- Provides merchants with their own database in which to store their customer information

For more back-end information on cybersecurity best practices and the BigCommerce platform, visit our Platform Trust Center and explore the following resources:

- The Current and Future State of Ecommerce Security
- Securing Your Ecommerce Site Against Cyber Threats
- Site-Wide HTTPS on BigCommerce
- SSL Certificate Overview



About the Author

Dan Holden is the VP, Cybersecurity at BigCommerce and has more than 25 years' experience across the cybersecurity and IT industries as a technology innovator and recognized cybersecurity expert. His broad areas of expertise include enterprise security, risk management, business development, cloud infrastructure, and new technology development.

Throughout his career, Mr. Holden has held leadership positions at companies including the Home Depot, the Retail & Hospitality ISAC, Arbor Networks, and TippingPoint. Over the last decade he has been a frequent speaker at major industry conferences including RSA, Defcon, and RVAsec. He has also been featured in many top publications, radio, and television around the world including Forbes, BBC, and Bloomberg. He is a Mentor with Austin-based cybersecurity group Manifest.